

软件安全考试大纲

- 1 概述 不考
- 2 缓冲区溢出基础
 - 2.1 缓冲区溢出原理
 - 2.2 进程内存空间分区
 - 2.3 系统栈的工作原理—内存的不同用途
 - 2.4 函数栈帧、函数调用原理
- 3 字符串安全
 - 3.1 常见的字符串操作错误
 - 3.2 不安全字符串 API
 - 3.3 字符串问题导致的安全漏洞
 - 3.4 缓解与防范措施
- 4 软件漏洞基础 不考
- 5 漏洞利用技术
 - 5.1 Shellcode 与 exploit 的概念
 - 5.2 栈帧移位与 jmp esp
 - 5.3 缓冲区的组成
- 6 漏洞挖掘与模糊测试
 - 6.1 fuzz 测试的概念与主要目标
 - 6.2 文件格式 fuzz 测试的主要步骤
 - 6.3 Smart fuzz 的主要特征
- 7 指针安全
 - 7.1 基本概念
 - 7.2 修改指令指针
 - 7.3 内存任意写技术
 - 7.4 虚函数
 - 7.5 SEH
 - 7.6 Windows 内存安全机制：GS 编译、DEP、Heap cookie、Safe Unlink、ASLR
- 8 格式化输出
 - 8.1 格式化输出函数原理
 - 8.2 典型的格式化输出函数和格式化符
 - 8.3 格式化输出函数可能导致的安全问题
 - 8.4 可扩展的缓冲区
 - 8.5 使程序崩溃
 - 8.6 覆写内存
 - 8.7 缓解与防范措施
- 9 整数安全
 - 9.1 整数表示方法：原码、反码、补码
 - 9.2 带符号和无符号整数
 - 9.3 整数取值范围
 - 9.4 整数转换、整形提升、隐式转换
 - 9.5 整数转换规则

- 9.6 整数溢出类别及原理：整数溢出、截断错误、符号错误
- 10 动态内存安全
 - 10.1 动态内存管理函数
 - 10.2 内存分配算法
 - 10.3 常见的内存错误
 - 10.4 Dlmalloc 空闲块管理
 - 10.5 解链技术（unlink 技术）
 - 10.6 Frontlink 技术
 - 10.7 RTL 堆基本概念
 - 10.8 RTL 堆可能存在漏洞